Solución S01 y pendientes de Diversify Delivery

Fecha: 9 de noviembre de 2026. Repositorio: kevinxonium153/DiversifyDelivery. Rama de pruebas: beta.

Resultado

Se corrigió el hallazgo de prioridad alta S01: un repartidor ya no puede consultar por ID pedidos sin asignar que todavía estén Recibido o que estén cerrados; tampoco puede quitarse de pedidos entregados o cancelados. La corrección está integrada sobre beta (base 2d55812) y comprobada. No se ha desplegado en producción.

Los otros siete hallazgos de seguridad siguen pendientes. Este cambio no los da por resueltos. El inventario completo de pendientes de seguridad, operación, producto y decisiones está en notas/Pendientes.md; el PDF `docs/Solucion_S01_y_todos_los_pendientes.pdf` incorpora ese inventario, incluyendo los avances existentes en beta de PixelPay y recuperación de contraseña.

Causa y cambio técnico

Archivo: src/Diversify.Delivery/Modules/Orders.cs, método MapDriver.

La consulta GET /api/driver/orders/{id} aceptaba cualquier pedido con DriverId nulo, aunque el listado de pedidos disponibles solo admitía Preparando o Listo. Conocer o adivinar el ID permitía consultar teléfono, dirección, instrucciones y coordenadas cuando existieran. Ahora la consulta exige que el pedido pertenezca al repartidor autenticado o que esté sin asignar y en Preparando/Listo. Los accesos no permitidos responden 404.

Regla de consulta implementada:

```
x.Id == id &&
(x.DriverId == me.UserId() || (x.DriverId == null &&
    (x.Status == OrderStatus.Preparando || x.Status == OrderStatus.Listo)))
```

La acción POST /api/driver/orders/{id}/release solo prohibía EnCamino. Ahora permite únicamente Preparando y Listo, siempre que quien la solicita sea el repartidor asignado. Los estados Recibido, EnCamino, Entregado y Cancelado se rechazan con 400. Otro repartidor recibe 404. La lectura, validación, actualización y evento de liberación se realizan en una transacción SQLite; un rechazo no persiste cambios.

Validación añadida, además de conservar el mensaje existente para EnCamino:

```
AppException.ThrowIf(o.Status is not (OrderStatus.Preparando or OrderStatus.Listo),
    "Solo puedes soltar pedidos que se estén preparando o estén listos. Los pedidos cerrados
conservan su repartidor.");
```

La transacción se inicia antes de cargar el pedido y se confirma después de SaveChangesAsync. No se cambiaron los datos históricos ni el esquema de base de datos. La carrera al tomar pedidos (S02) sigue pendiente.

Comportamiento esperado

- Pedido Recibido sin repartidor: consulta por repartidor devuelve 404.

- Pedido Preparando o Listo sin repartidor: consulta permitida, igual que el listado de disponibles.

- Pedido asignado a otro repartidor: consulta y liberación devuelven 404.

- Pedido propio Preparando o Listo: se puede soltar y se registra el evento.

- Pedido propio Recibido, EnCamino, Entregado o Cancelado: no se puede soltar; se conserva toda la información.

- Pedido propio entregado: sigue visible en el historial de su repartidor. El PIN permanece oculto.

- Pedido cerrado sin asignar: no queda expuesto por conocer su ID.

Los datos necesarios para repartir siguen visibles en pedidos realmente disponibles. Reducir los datos personales mostrados antes de aceptar una entrega es una decisión adicional de privacidad, fuera de esta corrección.

Validación ejecutada

- Compilación .NET 10 sobre beta con -warnaserror: correcta, sin advertencias ni errores. La advertencia CS9113 observada en master ya estaba corregida en beta antes de integrar S01.

- Regresión API tests/seguridad-repartidor.cjs: 62 comprobaciones correctas en una base demo nueva.

- El rechazo de una liberación se compara con el pedido completo anterior: estado, repartidor, fechas y eventos permanecen iguales. Se comprueban también el acceso al historial, PIN oculto y límites entre usuarios/roles.

- Recorrido existente tests/e2e-capturas.cjs: completó registro, pago simulado, pedido, preparación, salida, rechazo de PIN incorrecto y entrega correcta, sin errores de JavaScript.

- Las pruebas se ejecutaron en localhost:5493 con datos desechables; no se enviaron solicitudes a producción.

Prueba de regresión, desde la raíz del repositorio, con una app local de desarrollo y base demo desechable:

```
Storage__DataRoot="$(mktemp -d)" dotnet run --project src/Diversify.Delivery --launch-profile http
# En otra terminal:
ALLOW_DEMO_MUTATIONS=1 BASE=http://localhost:5390 node tests/seguridad-repartidor.cjs
```

El script crea cliente y pedidos propios y restaura ajustes al terminar; no limpia la base. No usar con datos reales. Debe finalizar con 62 comprobaciones correctas. Las instrucciones completas están en tests/README.md.

Entrega y comprobaciones posteriores

Revisar la corrección integrada en beta. Antes de producción, corregir el pendiente de rutas a delivery.env y verificar el paquete. Tras publicar, repetir casos de acceso por estado y liberación con cuentas de prueba. Revisar posibles pedidos históricos sin atribución o con eventos de liberación posteriores al cierre; esta corrección no repara automáticamente datos alterados previamente ni demuestra que hubo abuso real.

La auditoría original se realizó sobre master, commit a286c42. Sus resultados originales se conservan en el entorno de revisión; no constituyen una nueva auditoría completa de beta. La validación pública de Caddy/Cloudflare, TLS, host, dependencias y pasarela real sigue fuera de lo probado. No se garantiza ausencia de otras vulnerabilidades.

Inventario completo de pendientes

Estado al cierre de esta entrega. S01 está corregido localmente; el resto de casillas pendientes conserva su estado. Las decisiones de negocio requieren definición del responsable del producto.

Preguntas para definir (dueño del proyecto)

1. ~~Pasarela de pago~~ → **PixelPay** (definido 2026-11-09). Falta: credenciales del comercio (Key ID, llave secreta y URL del endpoint) y si cobra en HNL o USD.

2. **¿Un supermercado o varios?** ¿Delivery es solo para un súper (el de Diversify POS) o un mercado donde varios clientes de Diversify venden con sus propios repartidores? El modelo actual es un súper por instalación.

3. ~~La inscripción~~ → **pago único** (definido 2026-11-09). Por definir: ¿se reembolsa? ¿códigos promocionales?

4. **Facturación:** ¿el pedido debe crear la venta en Diversify POS (factura con CAI e inventario)? ¿Quién emite la factura y cuándo?

5. **Zonas y costo de envío:** ¿tarifa fija (hoy L 50) o por zona/colonia/distancia? ¿Hay zonas sin cobertura?

6. **Pagos de pedidos:** ¿efectivo, POS al recibir y transferencia son suficientes? ¿Pago en línea del pedido?

7. **Repartidores:** ¿empleados del súper o independientes? ¿Se les paga por entrega (comisión) y hay que llevar esa cuenta?

8. **Dominio:** ¿`delivery.diversify.hn` u otro?

9. **Notificaciones:** ¿WhatsApp automático (requiere WhatsApp Business API, con costo), SMS o correo?

10. **Logo propio** de "Diversify Delivery" o se queda la marca Diversify con la palabra DELIVERY.

Seguridad y operación (revisión del 9 de noviembre de 2026)

- [HECHO] S01: restringir consulta por ID a pedidos propios o disponibles (Preparando/Listo sin repartidor); impedir liberar pedidos Recibido, EnCamino, Entregado y Cancelado, conservando la atribución histórica. Validado con 62 comprobaciones de regresión. Solución en `docs/SOLUCION-SEGURIDAD-S01.md`.

- [PENDIENTE] S02: asignación atómica para evitar que dos repartidores tomen el mismo pedido simultáneamente.

- [PENDIENTE] S03: comprobar el máximo de tres pedidos pendientes dentro de la operación atómica de creación.

- [PENDIENTE] S04: protección antiforgery en operaciones autenticadas con efectos; validar orígenes como defensa adicional.

- [PENDIENTE] S05: revocación de la sesión en servidor al cerrar sesión (no solo eliminación de la cookie).

- [PENDIENTE] S06: una transferencia pendiente por usuario, límites por cuenta/IP e idempotencia.

- [PENDIENTE] S07: rechazar métodos de pago no definidos y validar reglas de cada método.

- [PENDIENTE] S08: validar y normalizar imágenes, incluyendo las importadas de Diversify POS.

- [PENDIENTE] Corregir las rutas a `delivery.env` en systemd y actualización; probar instalación nueva.

- [PENDIENTE] Validar IP real detrás de Caddy/Cloudflare y evitar acceso directo a Kestrel; añadir límites por cuenta.

- [PENDIENTE] Generar PIN con criptografía y limitar intentos por pedido/cuenta.

- [HECHO] Advertencia CS9113 (`httpFactory` sin usar) ya corregida en beta antes de integrar S01; compilación con `-warnaserror` verificada sin advertencias.

- [PENDIENTE] Desplegar S01 y repetir la validación en el entorno publicado; revisar atribuciones de pedidos históricos que pudieran haber sido alteradas antes de la corrección, sin reconstruirlas automáticamente.

- [PENDIENTE] Retomar guardado de la configuración reutilizable del entorno: la plataforma no confirmó el borrador.

Técnico

- [HECHO] Cobro de la inscripción con PixelPay: Hosted Payment, orden firmada (SHA3-512), regreso y aviso (`_callback`) verificados, prueba automática. Revisado con la documentación oficial (MCP de PixelPay).

- [PENDIENTE] Probar PixelPay con el sandbox real desde una computadora (desde la nube lo bloquea Cloudflare) y luego en producción. Confirmar el formato del aviso (`_callback`) con un pago real.

- [PENDIENTE] Mapa dentro de la app para marcar la ubicación (hoy: GPS del celular + enlaces a Google Maps/Waze). Requiere decidir proveedor de mapas (y permitir su dominio en la CSP).

- [PENDIENTE] Notificaciones push / WhatsApp de cambios de estado.

- [HECHO] Recuperar contraseña por correo (enlace de 1 hora y un solo uso; prueba automática).

- [PENDIENTE] Elegir el servicio de correo (Brevo, Gmail…) y configurarlo en el servidor (`Email__*`).

- [PENDIENTE] Enviar el pedido entregado a Diversify POS como venta (ver pregunta 4).

- [PENDIENTE] EF Core Migrations (hoy `EnsureCreated` + `SchemaUpgrades`, igual que Diversify POS).

- [PENDIENTE] Términos y condiciones y aviso de privacidad (texto legal).

- [PENDIENTE] PWA instalable (manifest + service worker) para clientes y repartidores.

- [PENDIENTE] Probar la instalación en el Proxmox real junto con Diversify POS.

Hecho

- [HECHO] Tienda en línea: catálogo público, búsqueda, ofertas, carrito, direcciones con GPS, pedido, seguimiento.

- [HECHO] Registro con inscripción de US$5 (tarjeta simulada / transferencia con aprobación).

- [HECHO] Panel master: tablero, pedidos kanban, ajuste de productos, asignación, productos y precios (rápido, masivo, historial), clientes e inscripciones, repartidores, ajustes.

- [HECHO] App del repartidor: disponibles, mis entregas, navegación, llamar/WhatsApp, entrega con código.

- [HECHO] Sincronización con Diversify POS (probada en local).

- [HECHO] Scripts de despliegue para un contenedor LXC aparte.

- [HECHO] Prueba de punta a punta con Playwright y capturas.

Detalle de los hallazgos aún pendientes

Evidencia de la auditoría local anterior a esta corrección. Los resultados siguientes no se presentan como reparados. La severidad es cualitativa y las condiciones de explotación se indican en cada caso. Actualización al integrar beta: CS9113 ya estaba corregido; la compilación estricta de esta entrega pasó sin advertencias. PixelPay y recuperación de contraseña ya están implementados según el inventario actualizado; sus pruebas con servicios reales siguen pendientes.

S02 · Media · Dos repartidores pueden tomar simultáneamente el mismo pedido

Ubicación: src/Diversify.Delivery/Modules/Orders.cs:402–413; no hay token de concurrencia en DeliveryDbContext.

La comprobación de DriverId y la escritura están separadas. En cinco de seis rondas con dos peticiones concurrentes, ambas devolvieron HTTP 200, cada una con su propio driverId; la base terminó con uno de ellos. Ambos clientes reciben confirmación válida y datos del pedido aunque solo uno queda asignado. Puede producir recogidas duplicadas y una bitácora confusa.

Corrección: asignación condicional atómica con predicado de estado/DriverId y comprobación de filas afectadas, o control de concurrencia optimista. Guardar asignación y evento juntos. El perdedor debe recibir 409 y refrescar el estado. Aplicar el mismo criterio al resto de transiciones susceptibles a carreras.

S03 · Media · Se evade el máximo de tres pedidos pendientes con concurrencia

Ubicación: src/Diversify.Delivery/Modules/Orders.cs:175 y 211–217.

El conteo ocurre antes de la transacción de inserción. Con cero pedidos Recibido del cliente demo, ocho peticiones simultáneas crearon seis pedidos (seis HTTP 201 y dos HTTP 400); la consulta posterior confirmó seis Recibido. No fue necesario alterar la base ni obtener permisos de administrador para ejecutar el ataque; la cuenta cliente estaba activa.

Corrección: hacer conteo e inserción dentro de una sección atómica adecuada a SQLite, con política explícita de bloqueo/reintento. Añadir límites por cuenta y protección contra reenvío accidental mediante claves de idempotencia. La prueba de regresión debe verificar el conteo persistido, no solo las respuestas.

S04 · Media, condicionada al origen atacante · CSRF en acciones con cookie

Ubicación: Program.cs:34–46 y endpoints POST sin validación antiforgery, especialmente Orders.cs:402.

SameSite=Lax separa sitios, no orígenes. Una página controlada por un atacante en otro origen del mismo sitio puede emitir un POST simple con credentials:include. Las acciones sin cuerpo no requieren JSON ni preflight. No se valida token antiforgery ni Origin.

Prueba real en Chromium: sesión de repartidor en http://127.0.0.1:5491; página atacante en http://127.0.0.1:5492; POST simple a /api/driver/orders/4/take. CORS bloqueó leer la respuesta, pero la acción sí asignó el pedido al repartidor 2. La sesión se había autenticado antes de abrir el origen atacante.

Condición: en producción requiere que el atacante controle un origen del mismo sitio (por ejemplo, un subdominio hermano bajo el mismo dominio registrable) o una posición equivalente. No se demostró CSRF autenticado desde un sitio externo arbitrario. La CSP del destino y CORS no evitan esta escritura.

Corrección: antiforgery en todas las operaciones con efectos, integrado con el cliente JavaScript; validar Origin/Referer y Fetch Metadata como defensa adicional. No confiar solo en SameSite ni en exigir JSON en algunos endpoints.

S05 · Media · Cerrar sesión no revoca una copia de la cookie

Ubicación: Modules/AuthEndpoints.cs:60–64; Core/Security.cs:45–87; Program.cs:39–40.

Logout solo elimina la cookie del navegador. Una copia previa de la cookie siguió obteniendo HTTP 200 en /api/driver/orders después de que logout respondiera 204. La cookie está configurada con expiración de 30 días y renovación deslizante.

Condición: el atacante debe haber obtenido una cookie válida; no se encontró una vía de robo de cookie en estas pruebas. El fallo es la ausencia de revocación después de logout, no un bypass de autenticación sin credenciales. No se midió la supervivencia durante 30 días.

Corrección: identificador de sesión y estado de revocación en servidor (ITicketStore o sesiones persistidas); revocar esa sesión al salir y ofrecer cierre de todas las sesiones. El stamp actual depende de propiedades del usuario, no de una sesión individual.

Controles positivos: cambiar contraseña invalidó la cookie anterior (401); suspender el usuario invalidó su sesión (401).

S06 · Media · Registros de transferencia sin límite por cuenta

Ubicación: Modules/RegistrationEndpoints.cs:87–108; no se aplica RequireRateLimiting a esa operación.

Una cuenta recién registrada pudo enviar 12 referencias diferentes en secuencia: las 12 devolvieron HTTP 200 y crearon solicitudes de revisión. No se exige resolver una solicitud pendiente antes de crear otra ni hay tope por cuenta. Esto puede llenar la cola del master y generar escrituras y registros innecesarios.

La prueba fue acotada; no se ejecutó una prueba de carga ni se demostró caída del servidor. Tampoco se movió dinero real.

Corrección: una única solicitud pendiente por usuario, cuota por cuenta e IP, idempotencia y restricciones de unicidad/estado en base de datos. Considerar verificación de correo y tratamiento de abuso.

S07 · Baja · Método de pago fuera del enum aceptado

Ubicación: Program.cs:18–19 y Modules/Orders.cs:189–207.

Enviar paymentMethod:999 creó un pedido con HTTP 201 y paymentMethod:"999". JsonStringEnumConverter permite enteros y el endpoint no verifica Enum.IsDefined. Esto persiste estados no soportados y evita la rama de validación específica de Efectivo.

No se demostró obtención de productos gratis: el mismo intento de enviar total:0 y price:0 fue ignorado y el servidor calculó L 550, con subtotal esperado L 500 y envío L 50.

Corrección: rechazar valores no definidos, desactivar enteros en el conversor si no son parte del contrato y validar las reglas de cada método de pago en servidor.

S08 · Baja · Imagen inválida aceptada y error público 500

Ubicación: Core/Formats.cs:25–31; Modules/CatalogEndpoints.cs:60–67.

El master pudo crear un producto con imageData:"!": HTTP 201. La lectura pública de su imagen respondió HTTP 500 porque se decodifica sin validar previamente Base64 ni contenido real.

Requiere permisos de master para la carga directa; por eso no se califica como caída pública de toda la aplicación ni como ejecución de código. La importación desde POS también copia ImageData sin pasar por Text.Image (DiversifySync.cs:147), lo que amplía el problema a datos de integración y merece validar MIME y contenido antes de servirlos.

Corrección: decodificar al importar/subir, limitar bytes y dimensiones, comprobar formato real y normalizar a una imagen permitida. Aplicar la misma validación a la sincronización. Una imagen inválida debe producir 400 al cargarse y no un 500 en el catálogo.

Riesgos de despliegue y observaciones separadas

- **Configuración de systemd inconsistente, confirmada por revisión:** deploy/install.sh crea /etc/diversify-delivery/delivery.env, pero deploy/systemd/diversify-delivery.service:13 y deploy/update.sh:19 usan /etc/diversify-delivery-delivery/delivery.env. Con los archivos tal como están, una instalación nueva puede no arrancar y una actualización no leer el puerto correcto. No se ejecutó una instalación de producción; corregir las rutas y probar el paquete en un contenedor desechable.

- **Límite por IP dependiente del proxy:** tras alcanzar 429 en localhost, cambiar X-Forwarded-For devolvió 401 y permitió otro intento. El peer local es un proxy de confianza de ASP.NET. Esto confirma el comportamiento en acceso directo local, no un bypass remoto en Caddy. Mantener Kestrel en loopback, impedir acceso directo y verificar que Caddy/Cloudflare reescriben y no aceptan IP arbitraria del visitante. Añadir límite por cuenta; el PIN de entrega comparte la política por IP.

- **PIN:** se genera con Random.Shared.Next(1000,10000). Usar RandomNumberGenerator.GetInt32 y un presupuesto de intentos por pedido/cuenta, además del límite por IP. No se intentó fuerza bruta completa ni se predijo un PIN.

- **CI:** la compilación limpia con -warnaserror falla por CS9113, parámetro httpFactory sin usar en Modules/DiversifySync.cs:25. Defecto de calidad/operación, no vulnerabilidad de explotación demostrada.